

Universidad Nacional De Asunción

Facultad Politécnica

Ingeniería En Informática



Propuesta de Trabajo Final de Grado
Comparativa OCSVM vs enfoques multi-
etiqueta en tráfico HTTP real: integración de
SR-BH 2020 y enriquecimiento de features

Autores:

- Andrés Román

Año de ingreso: 2021-2025

CI: 5.436.434

- Juan González

Año de ingreso: 2021-2025

CI: 5.207.720

Tutor:

Dr. Cristian Cappo

1- Motivación

Las aplicaciones web han tenido un crecimiento constante en la última década, convirtiéndose en infraestructuras críticas para servicios de comercio, comunicación y administración. Sin embargo, al estar expuestas a través de la red, siguen siendo objetivo de una amplia variedad de ataques dirigidos al protocolo HTTP (Hypertext Transfer Protocol), tales como inyecciones, cross-site scripting y ataques de traversal [1]. En muchos casos, las aplicaciones no implementan las mejores prácticas de seguridad, o bien priorizan la incorporación de funcionalidades por encima de la robustez y los controles, exponiendo la infraestructura a riesgos potenciales de pérdida de datos, interrupción del servicio y brechas de seguridad.

En este contexto, los sistemas de detección y prevención de intrusiones (IDS – Intrusion Detection System, IPS – Intrusion Prevention System) y, particularmente, los cortafuegos para aplicaciones web (WAF – Web Application Firewall), juegan un rol fundamental para identificar y mitigar ataques en tiempo real. El uso de técnicas de aprendizaje de máquinas (ML – Machine Learning) permite mejorar la detección de comportamientos anómalos y descubrir patrones emergentes que no están cubiertos por reglas estáticas [2], [3], [4]. En particular, los enfoques de clasificación de una sola clase (OCC – One-Class Classification), como One-Class SVM, son atractivos para escenarios con escasez de muestras rotuladas de ataques o con alta variabilidad de tráfico normal [5], [6].

Este trabajo toma como punto de partida el proyecto base de Nico Ralf [1], retomando la idea de incorporar detección de anomalías en un WAF y extendiéndola con nuevas fuentes de datos y características (features) centradas en HTTP. La ampliación propone integrar un dataset de tráfico real etiquetado a nivel de patrones de ataque, lo cual permite evaluar no solo la detección binaria (normal/anómalo), sino también la clasificación por tipo de ataque, aumentando la utilidad operativa de los resultados.

2- Objetivos

El objetivo general es diseñar, implementar y evaluar un prototipo de WAF que incorpore técnicas de ML para la detección de anomalías y la clasificación por tipo de ataque en HTTP, utilizando datasets representativos del tráfico web.

Objetivos específicos:

1. Integrar nuevas fuentes de datos, incorporando un dataset de tráfico real etiquetado a nivel de patrones de ataque y compararlo con datasets utilizados en trabajos anteriores.
2. Diseñar y extraer nuevas features específicas de HTTP, relacionadas con la estructura de la URI (Uniform Resource Identifier), el método de la solicitud, los parámetros de query, la presencia de tokens sospechosos en el contenido y el uso de métodos poco comunes. La motivación de esta selección radica en que tales rasgos han sido vinculados directamente con patrones de explotación típicos en ataques web modernos [4].

3. Analizar el impacto de las nuevas *features* en la capacidad de detección y clasificación de los modelos, identificando cuáles contribuyen más a la discriminación entre tráfico normal y malicioso.
4. Evaluar la viabilidad de aplicar los enfoques propuestos en escenarios de tráfico real en tiempo casi real, considerando el costo computacional y la escalabilidad.

3- Descripción de la propuesta

Este trabajo amplía y actualiza el proyecto base de Nico Ralf [1], integrando un WAF experimental con etiquetado por tipo de ataque y nuevas características de tráfico HTTP. La ampliación se centra en incorporar el dataset SR-BH 2020, publicado en Harvard Dataverse [7], el cual contiene tráfico web real capturado con ModSecurity en un honeypot y etiquetado manualmente a nivel de patrones Common Attack Pattern Enumeration and Classification (CAPEC). Esta fuente de datos introduce mayor realismo (volumen y diversidad), permitiendo la comparación con los escenarios anteriores basados en CSIC/TorpEda y, además, habilitando la evaluación multiclase y, cuando aplique, multietiqueta. En la literatura reciente (2024–2025), el dataset se utiliza como referente para evaluación multietiqueta y reportes por clase CAPEC, facilitando la comparabilidad de resultados y su validez externa.

Objetivos específicos de la ampliación

1- Integración de un nuevo dataset realista: incorporar SR-BH 2020 [7] y compararlo con escenarios heredados (CSIC-2010/TorpEda-2012), elevando el realismo y la diversidad (más de 900k solicitudes, 24 características y 13 etiquetas a nivel CAPEC).

2- Etiquetado por tipo de ataque: pasar de un esquema binario (normal/anómalo) a clasificación por clase de ataque (*multiclase*) y, cuando corresponda, evaluar en configuración multietiqueta con métricas como *Hamming Loss* y Medida armónica de precisión y *recall* (F1-score) macro/micro.

3- Nuevas *features* de solicitudes HTTP: diseñar y extraer rasgos adicionales de capa aplicación orientados a mejorar la detección y clasificación:

- `uri_len`: longitud de la URI.
- `path_depth`: cantidad de "/" en el *path* (sin *query*).
- `query_len`: longitud de la *query string*.
- `n_param_params`: cantidad de parámetros en la *query*.
- `max_len`: longitud máxima entre los valores de parámetros.
- `uri_pct_non_hex_alnum_ratio`: proporción de caracteres no alfanuméricos en la URI.
- `encoded`: porcentaje de secuencias %xx (*URL-encoding*) en la URI.
- `suspicious_tokens`: presencia/conteo de *tokens* sospechosos (`../`, `<script`, `onerror=`, `'`, `"`, `--`, `;`, `union`, `select`, `sleep(`, or `1=1`).
- `uncommon_method` y codificación *one-hot* del método HTTP.

- req_content_length: *Content-Length* de la solicitud (0 si no está presente).

Véanse, por ejemplo, [8], [9], [10], [11].

4- Comparativa de modelos: replicar y extender los experimentos con One-Class SVM y establecer *baselines* supervisados (p. ej., máquina de vectores de soporte —SVM, *Support Vector Machine*—, árboles y *ensembles*), evaluando el impacto del nuevo etiquetado y de las *features*.

5- Prototipo de WAF: integrar los mejores modelos en un prototipo con modo pasivo (registro) y modo activo (detección y respuesta configurable).

Metodología y diseño experimental

1- Preprocesamiento y *parsing*: extracción de campos HTTP y cálculo de *features* (p. ej., path_depth, longitudes de URI/query/parámetros, proporciones de caracteres y codificación).

2- Etiquetado y particionado: uso de etiquetas CAPEC provistas por SR-BH 2020 para configurar tareas binarias vs. multiclase y, si aplica, multietiqueta; particionado estratificado por clase.

3- Entrenamiento y selección: comparación de One-Class SVM frente a *baselines* supervisados; búsqueda de hiperparámetros mediante *grid search/random search* con validación cruzada.

4- Métricas: precisión, *recall*, F1-score (macro/micro), curvas ROC (*Receiver Operating Characteristic*) y AUC (cuando corresponda); *Hamming Loss* para experimentos multietiqueta.

5- Ablaciones e importancia de *features*: análisis del aporte marginal de cada *feature* y de grupos de *features*.

6- Integración WAF: *pipeline* de inferencia (modo pasivo/activo) y registro de evidencias para auditoría.

4- Alcance y limitaciones

Alcance

1- Integra y compara los escenarios heredados del proyecto base con SR-BH 2020 [7].

2- Aborda la detección y clasificación por tipo de ataque en la capa de aplicación.

3- Diseña y evalúa un conjunto de *features* HTTP adicionales.

4- Entrega un prototipo funcional de WAF y resultados reproducibles (código y *notebooks*).

Limitaciones

1- **Cobertura de clases:** se depende de las clases CAPEC presentes; las clases minoritarias pueden inducir *imbalance*.

2- **Generalización:** la captura de SR-BH 2020 se realizó en un entorno específico (honeypot/ModSecurity); otras organizaciones podrían requerir recalibración.

3- **Costo computacional:** el cálculo de nuevas *features* y la clasificación multiclase aumentan tiempo y uso de memoria; se limitará el número de configuraciones evaluadas.

4- **Privacidad/ética:** uso exclusivo de *datasets* públicos/anonimizados; no se recolectan datos personales.

5- Alcance y limitaciones

Fase	Entregables principales
1. Revisión y diseño (sem. 1–2)	Protocolo experimental; definición final de <i>features</i> ; plan de etiquetado/clases.
2. Ingesta y preprocesamiento (sem. 3–4)	Parsers HTTP; cálculo de <i>features</i> ; EDA y análisis de <i>imbalance</i> .
3. Modelado inicial (sem. 5–6)	<i>Baselines</i> (OCC/OCSVM y supervisados simples); métricas base; <i>benchmark</i> binario vs. multi-clase.
4. Ablaciones y selección (sem. 7–8)	Importancia de <i>features</i> ; mejores modelos e hiperparámetros.
5. Integración WAF (sem. 9)	Prototipo con modo pasivo/activo; registro de eventos; documentación técnica.
6. Redacción y validación (sem. 10)	Informe final, anexos reproducibles y presentación.

Tabla 1: Plan de actividades propuesto.

6- Referencias

[1] Carmen Giménez, Alejandro Pérez, and Gonzalo Álvarez. Trabajo final (base del proyecto Nico Ralf). , 2015. Accessed: 2025-09-16.

[2] Anna L. Buczak and Erhan Guven. A survey of data mining and machine learning methods for cyber security intrusion detection. IEEE Communications Surveys & Tutorials, 2016.

[3] Christopher Kruegel and Giovanni Vigna. Anomaly detection of web-based attacks. In Proceedings of the 10th ACM Conference on Computer and Communications Security. ACM, 2003.

[4] H. Nguyen et al. Application anomaly detection: Taxonomy, methods and systems. ACM Computing Surveys, 2011.

[5] Shehroz S. Khan and Michael G. Madden. A survey of recent trends in one-class classification. In Irish Conference on Artificial Intelligence and Cognitive Science. Springer Berlin Heidelberg, 2009.

- [6] Elham Parhizkar and Mahdi Abadi. OC-WAD: A one-class classifier ensemble approach for anomaly detection in web traffic. In 2015 23rd Iranian Conference on Electrical Engineering (ICEE). IEEE, 2015.
- [7] Harvard Dataverse. HTTP anomalous traffic dataset. <https://dataverse.harvard.edu/dataset.xhtml?persistentId=doi:10.7910/DVN/OG OIXX>, 2020. Accessed: 2025-09-16.
- [8] Tomás Sureda Riera, Juan Ramón Bermejo Higuera, Javier Bermejo-Higuera, José Javier Martínez Herraiz, and Juan Antonio Sicilia. A new multi-label dataset for web attacks CAPEC classification using machine learning techniques. *Computers & Security*, 120:102788, 2022.
- [9] Amanda Riverol, Gustavo Betarte, Rodrigo Martínez, and Álvaro Pardo. Capturing the security expert knowledge in feature selection for web application attack detection. In *Proceedings of the Latin-American Symposium on Dependable Computing (LADC 2024)*, pages 153–158, 2024. Preprint disponible también como arXiv:2407.18445.
- [10] Menghao Fang, Yixiang Wang, Liangbin Yang, Haorui Wu, Zilin Yin, Xiang Liu, Zexian Xie, and Zixiao Kong. Reinventing web security: An enhanced cycle-consistent generative adversarial network approach to intrusion detection. *Electronics*, 13(9):1711, 2024.
- [11] Yonghang Zhou, Hongyi Zhu, Yidong Chai, Yuanchun Jiang, and Yezheng Liu. Towards trustworthy web attack detection: An uncertainty-aware ensemble deep kernel learning model. , 2024. Preprint, experimentos sobre los datasets BDCI y SR-BH 2020.